Signed by
Transition RAC
RADIX DAO LLC

Source Code Stewardship Policy

---

1. Purpose

This policy defines how the DAO manages, maintains, and governs source code and software assets held on behalf of the ecosystem — including assets received from Asset Transferors and assets produced by Working Groups or funded through Governance Proposals.

It ensures that:

- transferred source code is preserved, accessible, and maintained to a defined standard
- the community retains sovereignty over protocol-level software changes
- security vulnerabilities are responsibly disclosed and patched
- the development history of DAO-controlled code is transparent and auditable

---

2. Scope

This policy applies to:

- all software repositories under the control of the DAO's Web2 Custodian or Treasury Signers
- Source Code received from Asset Transferors and listed in an IP Schedule
- software produced by Working Groups or funded through Governance Proposals
- smart contracts deployed to mainnet by or on behalf of the DAO

It does not apply to software produced by independent ecosystem projects that receive grants but are not under DAO control.

---

3. Repository Governance

3.1 Official Repositories

The Web2 Custodian maintains a public registry of all repositories under DAO control. This registry is published on the governance forum and updated within 7 days of any change.

Each entry in the registry must record:

- repository name and URL
- the applicable license
- the Working Group or role responsible for maintenance
- the date the repository came under DAO control, and the commit hash at that point

3.2 Access Control

Write access to any DAO-controlled repository requires:

- identity verification (KYC or equivalent) for any individual with merge authority
- role-based access: only designated maintainers may merge to protected branches
- maintainers are appointed by the relevant Working Group or by Governance Proposal

No individual may hold sole admin access to a DAO-controlled repository. Admin access must be held by at least two individuals in different roles, with the Web2 Custodian holding backup access.

3.3 Repository Protection

The Web2 Custodian must configure each DAO-controlled repository with the following protections on the main branch:

- pull request review required before merge (minimum 1 reviewer for routine changes; minimum 2 for protocol-level changes)
- direct pushes to main branch disabled
- force pushes disabled
- branch deletion protection enabled

Repositories may not be deleted, transferred, or renamed without a Governance Proposal.

---

4. Versioning and Branching

4.1 Versioning Convention

All DAO-controlled software released to mainnet must use **Semantic Versioning (SemVer)**:

- `MAJOR.MINOR.PATCH` format
- MAJOR: breaking changes or significant protocol changes
- MINOR: new features, backwards-compatible
- PATCH: bug fixes and security patches

4.2 Branching Strategy

Each repository must maintain:

- `main` — production-ready code, protected
- `develop` — integration branch for next release
- Feature branches named `feature/[description]`
- Hotfix branches named `hotfix/[description]` for emergency patches

4.3 Release Tagging

Every production release must be tagged in the repository with its version number and accompanied by a changelog entry describing all changes since the previous release. Tags must be signed by at least one designated maintainer.

---

5. Code Review Process

5.1 Routine Changes

All changes to DAO-controlled repositories must be submitted as pull requests and reviewed before merging. For routine changes:

- minimum 1 approving review from a designated maintainer
- automated tests must pass before merge
- the pull request must be open for a minimum of 24 hours before merging (excluding emergency patches under §7)

5.2 Protocol-Level Changes

Changes that affect the core protocol logic, consensus mechanisms, tokenomics, or security-critical components require:

- minimum 2 approving reviews, at least one of which must be from a maintainer outside the Working Group proposing the change
- an RFC published to the governance forum for community review (minimum 7 days)
- a security review under §6 for any change with security implications
- where applicable, a Governance Proposal confirming community approval before merge

Protocol-level changes are identified by the relevant Working Group and the RAC at the time of proposal.

5.3 Review Standards

Reviewers are expected to assess:

- correctness and alignment with the approved specification
- security implications
- test coverage
- documentation completeness
- compliance with the applicable open-source license

---

6. Security Vulnerability Management

6.1 Responsible Disclosure

The DAO operates a responsible disclosure process for security vulnerabilities in DAO-controlled software. Vulnerability reports should be submitted to the RAC via the channel published in the governance forum (not in public channels).

The RAC acknowledges receipt within 48 hours and assesses severity within 7 days.

6.2 Severity Classification

Severity	Definition	Target Patch Timeline
Critical	Remote exploit, loss of funds, consensus failure	72 hours
High	Significant security risk, no immediate exploit	7 days
Medium	Limited impact, requires specific conditions	30 days
Low	Minimal risk, informational	Next scheduled release

6.3 Disclosure Policy

- Critical and High vulnerabilities are patched before public disclosure.
- After a patch is deployed, a public disclosure is published within 7 days (Critical) or 14 days (High) detailing the vulnerability, its impact, and the fix.
- Medium and Low vulnerabilities may be disclosed alongside the patch.
- This policy does not create a bug bounty programme. Vulnerability rewards, if any, are governed by a separate policy adopted by Governance Proposal.

6.4 Dependency Management

The relevant Working Group is responsible for:

- maintaining an up-to-date dependency manifest for each DAO-controlled repository
- reviewing dependency security advisories at least monthly
- updating or replacing vulnerable dependencies within the timelines in §6.2
- publishing a quarterly dependency health report to the governance forum

---

7. Emergency Patching

7.1 Trigger

An emergency patch may be initiated when:

- a Critical or High severity vulnerability has been identified
- delayed patching would result in material harm to the ecosystem, treasury assets, or network stability

7.2 Authority

The RAC, in coordination with the relevant Working Group maintainers, may authorize an emergency patch without the standard RFC and review periods in §5.2. Emergency patches still require:

- minimum 2 approving reviews from designated maintainers
- documentation of the vulnerability and the fix before deployment
- disclosure to the governance forum within 48 hours of deployment

7.3 Retrospective Review

An emergency patch must be submitted to a full retrospective community review via Governance Proposal within 14 days of deployment. The community may ratify, modify, or revert the patch.

---

8. Release Procedure

8.1 Release Checklist

Before deploying any release to mainnet, the responsible Working Group must confirm:

- ☐ All pull requests in scope have been reviewed and merged
- ☐ All automated tests pass on the release candidate
- ☐ Changelog is complete and accurate
- ☐ Version number is correct per SemVer
- ☐ Security review completed (if applicable under §5.2)
- ☐ Governance Proposal confirmed (if required for protocol-level changes)
- ☐ Independent audit completed where required by the relevant Working Group charter or by the terms of a Governance Proposal for protocol-level releases
- ☐ Release tag created and signed

8.2 Deployment Authorization

For protocol-level releases: the Treasury Signers confirm deployment authorization matches the Governance Proposal before any on-chain deployment is executed.

For routine releases: the relevant Working Group Steward confirms deployment readiness in writing to the governance forum before release.

8.3 Post-Release Monitoring

The responsible Working Group monitors the release for 72 hours post-deployment and publishes a post-deployment status report to the governance forum. Any regression that triggers an emergency patch must follow §7.

---

9. Assets Received from Asset Transferors

9.1 Intake

When Source Code is received from an Asset Transferor under an Asset Transfer Agreement:

- the Web2 Custodian forks or transfers the repository to DAO-controlled access
- the commit hash at transfer is verified against the IP Schedule
- the applicable license is confirmed and recorded in the repository registry
- an Acceptance Statement is issued as required by the Asset Transfer Agreement

9.2 Maintenance Responsibility

Once accepted, the DAO assumes full maintenance responsibility for transferred Source Code. The relevant Working Group assigns maintainers within 30 days of acceptance. Where no relevant Working Group yet exists for a transferred asset, the RAC assigns interim maintainers and a Governance Proposal is initiated to establish or designate a responsible Working Group.

9.3 License Obligations

The applicable license for each transferred repository is maintained and must be:

- preserved in all forks and derivative works produced by the DAO
- clearly displayed in the repository's root directory
- referenced in any Governance Proposal that proposes modifications or redistribution

Any proposed change to the license of a transferred repository requires a Governance Proposal.

---

10. Governance

10.1 Responsible Body

The relevant Working Group (the Product & Protocol Working Group or its successor, once established by Governance Proposal) is responsible for enforcement of this policy. Pending establishment of that Working Group, the RAC discharges this responsibility.

10.2 Quarterly Review

The responsible body publishes a quarterly Source Code Health Report to the governance forum covering:

- a summary of all releases in the quarter
- security vulnerabilities identified and resolved
- dependency health status
- any repositories added to or removed from DAO control
- outstanding maintenance obligations

10.3 Policy Amendments

Changes to this policy require a Governance Proposal following the Governance Maintenance & Upgrade Framework.

---

11. Relationship to Other Policies

This policy operates alongside:

- **Open Source & Intellectual Property Policy** — licensing obligations for all DAO-funded and transferred assets
- **Emergency & Safeguards Policy** — emergency response authority for security incidents affecting code
- **Working Group Framework** — Working Group authority and reporting obligations
- **Governance Maintenance & Upgrade Framework** — amendment procedures

Audit and formal vulnerability-reward regimes may be added by future Governance Proposal.

---

12. Amendments

*Amendment procedures and classification requirements are defined in the **Governance Maintenance & Upgrade Framework**.*

---

13. Guiding Principle

> The DAO receives code as a public trust. Maintaining it is not optional — it is the obligation that comes with stewardship.